

GRC104 - Compliance Frameworks and Legal Requirements

Overview of Global Compliance Frameworks

International Cybersecurity and Digital Forensics Academy
Directorate of Ethics and Discipline

Week 16: Oct 27 - Nov 2, 2025



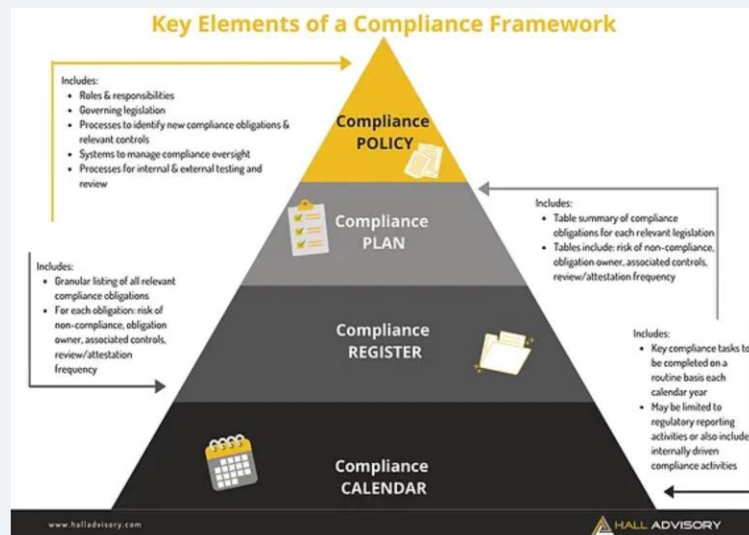
Introduction to Global Compliance Frameworks

What is a Compliance Framework?

A structured set of guidelines, rules, and best practices designed to help organizations manage regulatory requirements systematically and ensure adherence to legal, ethical, and industry standards.

Why Global Compliance Matters:

- ✓ **Mitigate Risks:**
Avoid legal penalties, financial losses, and reputational damage
- ✓ **Build Trust:**
Enhance stakeholder confidence and market credibility
- ✓ **Operational Efficiency:**
Streamline processes and reduce redundancies
- ✓ **Global Reach:**
Essential for organizations operating across multiple jurisdictions



Why Global Compliance Matters

Strategic Importance of Compliance

Benefit	Description
Risk Mitigation	Prevents legal penalties, financial losses, and reputational damage
Competitive Advantage	Builds customer trust and market credibility
Operational Excellence	Standardizes processes and improves efficiency
Global Market Access	Enables operations across multiple jurisdictions

Evolution of Compliance Landscape

-  Growing regulatory requirements across regions
-  Heightened focus on data protection and privacy
-  Increased stakeholder expectations for corporate responsibility



Key Global Regulatory Frameworks (Part 1)



GDPR (General Data Protection Regulation)

The European Union's comprehensive data protection law that reshapes how organizations handle personal data of EU residents, regardless of the organization's location.

Key Requirements:

- Legal basis for data processing
- Data subject rights (access, erasure, portability)
- Data breach notification within 72 hours
- Data Protection Officer appointment
- Privacy by design and default

Penalties: Up to €20M or 4% of annual global revenue



HIPAA (Health Insurance Portability and Accountability Act)

U.S. federal law protecting sensitive patient health information from disclosure without consent.

Key Requirements:

- Privacy Rule (PHI protection)
- Security Rule (electronic PHI safeguards)
- Breach Notification Rule
- Minimum Necessary Rule
- Omnibus Rule (business associate responsibilities)

Penalties: Range from \$100 to \$1.5 million per violation

Key Global Regulatory Frameworks (Part 2)



SOX (Sarbanes-Oxley Act)

U.S. federal law enacted in 2002 to improve corporate governance and accountability, preventing accounting fraud following major corporate scandals.

- ✓ **Corporate responsibility** for financial reports
- ✓ **Management assessment** of internal controls
- ✓ **Strict recordkeeping** requirements
- ✓ **Penalties** for wrongful certifications

➔ **Enforced by:** Securities and Exchange Commission (SEC)



PCI DSS (Payment Card Industry Data Security Standard)

Global security standard for organizations that handle credit card information, designed to protect cardholder data.

- ✓ Build and maintain **secure networks**
- ✓ **Protect cardholder data** in transit and at rest
- ✓ Maintain **vulnerability management** program
- ✓ Implement **strong access control** measures
- ✓ **Regularly monitor and test** networks
- ✓ Maintain **information security policy**

⚠ **Penalties:** Fines from \$5,000-\$100,000 per month, increased transaction fees, or termination of card payment acceptance

Key Global Information Security Frameworks (Part 1)



ISO/IEC 27001

International standard for Information Security Management Systems (ISMS), providing a systematic approach to managing sensitive information.

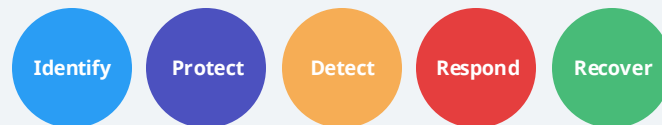
- ✓ **Risk assessment and treatment** methodology
- ✓ **Leadership commitment** to information security
- ✓ **93 security controls** across organizational, people, physical, and technological domains
- ✓ **Certification valid for 3 years** with annual surveillance audits
- ✓ **Continuous improvement** through Plan-Do-Check-Act cycle

Key Benefit: Internationally recognized standard that demonstrates commitment to information security best practices



NIST Cybersecurity Framework

Developed by the U.S. National Institute of Standards and Technology, this framework provides a flexible, organized approach to managing cybersecurity risk.



- ✓ **Flexible implementation** adaptable to organizations of all sizes
- ✓ **Risk-based approach** to prioritize cybersecurity activities
- ✓ **Common language** for cybersecurity discussions
- ✓ **Integration** with business and organizational needs
- ✓ **NIST CSF 2.0** will add "Govern" as sixth core function

Key Benefit: Adaptable framework that can be tailored to specific organizational risk profiles and business needs

Key Global Information Security Frameworks (Part 2)



COBIT (Control Objectives for Information and Related Technologies)

Developed by ISACA, COBIT aligns IT governance and management with business objectives.

- ✓ **Governance and management objectives** for enterprise IT
- ✓ **Performance management** through metrics and maturity models
- ✓ **Risk optimization** strategies and frameworks
- ✓ **Resource optimization** for IT investments
- ✓ **Stakeholder value delivery** through balanced decision-making

Primary Focus: Bridging the gap between business requirements, control needs, and technical issues



CMMC (Cybersecurity Maturity Model Certification)

Designed for the U.S. Department of Defense supply chain to enhance protection of sensitive defense information.

- 1 **Foundational** - Basic cybersecurity practices, may be implemented ad-hoc
- 2 **Advanced** - Documented, repeatable processes with intermediate cybersecurity
- 3 **Expert** - Strategies for advanced persistent threats and sophisticated attacks

Implementation Timeline: Mandatory for DoD contractors by 2026

Challenges in Global Compliance

Key Obstacles Organizations Face

Challenge	Description
Regulatory Complexity	Navigating regulations across different jurisdictions
Constant Evolution	Keeping pace with rapidly changing laws and standards
Resource Constraints	Allocating sufficient budget, personnel, and expertise
Technology Integration	Implementing effective monitoring systems

Impact of Non-Compliance



Financial penalties



Reputational damage



Market access restrictions



Best Practices for Global Compliance

Strategic Approaches to Effective Compliance

Risk-Based Approach

Prioritize compliance efforts based on risk assessment, focusing resources on areas with the highest potential impact and likelihood of occurrence.

Integrated GRC Framework

Implement a unified Governance, Risk, and Compliance strategy rather than managing compliance requirements in silos, enabling better visibility and coordination.

Technology Enablement

Leverage GRC platforms and automation tools to streamline compliance processes, improve monitoring capabilities, and generate comprehensive reports.

Culture of Compliance

Foster an organization-wide commitment to compliance, starting with leadership's tone at the top and extending through regular training and awareness programs.

Continuous Monitoring

Implement real-time monitoring systems to detect non-compliance issues promptly, allowing for timely remediation and process improvement.



Helpful Tips for Healthcare Compliance Officers

Professionals responsible for compliance management seem to run short on time due to competing priorities and multiple projects. Gain control over the schedule by utilizing some common advice.

Set Realistic Goals Spend some time assessing your needs and areas of risk and then plan your course of action accordingly.	Eliminate Obstacles Identify the time blocks during your day that could be spent more productively.
Create a Habit If you can create a habit of starting work a little earlier one day each month, you might find the path to greater productivity and crossing one more item off your list.	Seek Assistance Remember that you don't have to face the daunting task of compliance management alone. Delegate more or consider hiring an expert.
Embrace Technology Managing compliance entails a list of repetitive tasks. From high-level organizational risk assessments and audits to simple reminders and resource documents, compliance management software can help improve your efficiency.	

Comprehensive Healthcare Compliance Management Solutions
CONFIDENCE INCLUDED

Creating confidence among compliance professionals through education, resources, and support

1st Healthcare Compliance
888.54.FIRST 1sthec.com

Conclusion & Key Takeaways

Summary of Global Compliance Frameworks

Global compliance frameworks provide essential structure for organizations navigating complex regulatory environments.

- ✓ The **fundamental purpose** of compliance frameworks in today's global business landscape
- ✓ Key regulatory frameworks including **GDPR, HIPAA, SOX, and PCI DSS**
- ✓ **ISO 27001, NIST CSF, COBIT, and CMMC**
Major information security frameworks such as
- ✓ Common **challenges** organizations face in achieving global compliance
- ✓ **Best practices** for implementing effective compliance programs

Critical Success Factors

Proactive Approach



Rather than reactive response to regulatory requirements

Executive Sponsorship



Clear accountability for compliance outcomes

Integrated Systems



Comprehensive visibility across the organization

Continuous Improvement



Regular assessment and adaptation

Thank You & Resources

Further Resources

Official Framework Documentation

[!\[\]\(4729e517bc6a7cd81c8025b9646574fb_img.jpg\) GDPR](#)[!\[\]\(cbe80b694ebd74fcfe136a095b608235_img.jpg\) HIPAA](#)[!\[\]\(a03a7eb2f4046e1d3c76772003e549ea_img.jpg\) SOX](#)[!\[\]\(cbe2492b119e39e02a1dab2af4a4b296_img.jpg\) PCI DSS](#)[!\[\]\(e474458956c9a37fbf9586ddb60a7fa1_img.jpg\) ISO 27001](#)[!\[\]\(3e2231b1ad3ca8da8658228c00dd08e0_img.jpg\) NIST CSF](#)[!\[\]\(5361750c22c4e047a52f4eac1ec2d4cc_img.jpg\) COBIT](#)[!\[\]\(870f5d5e9c0d57485634be3ecf52f3ca_img.jpg\) CMMC](#)

Recommended Reading

"The Compliance Handbook: A Guide to Operationalizing Your Compliance Program"

"IT Governance: An International Guide to Data Security and ISO 27001/ISO 27002"

"NIST Cybersecurity Framework: A Practical Implementation Guide"

Thank you for your attention!